TÀI LIỆU ĐẶC TẢ NGHIỆP VỤ & KIỂM THỬ

CHU TRÌNH XÁC THỰC E-SERVICE CHO CÁN BỘ BỘ GIÁO DỤC (MOEHQ) & NHÀ TRƯỜNG (SCHOOL)

KIẾN TRÚC PURE BFF (PATTERN 2) - USERNAME & PASSWORD

MỤC LỤC

1. Tổng quan Nghiệp vụ & Sơ đồ Tuần tự (Executive Abstract & Topology)
2. Bản đồ Tác nhân & Ma trận Vai trò (Service Registry & Roles Matrix)
3. Đặc tả Chi tiết 4 Bước Xác thực & Dữ liệu Mẫu (Step-by-Step Payloads)
4. Sổ tay "Soi" Dữ liệu Dành cho QA (QA DevTools & Inspection Cheatsheet)
5. Ma trận Kịch bản Kiểm thử Nghiệp vụ (QA Test Matrix)
6. Tiêu chí Nghiệm thu Tính năng (Sign-off Acceptance Checklist)

---

1. TỔNG QUAN NGHIỆP VỤ & SƠ ĐỒ TUẦN TỰ (EXECUTIVE ABSTRACT & TOPOLOGY)

1.1 Khái quát chu trình nghiệp vụ

Hệ thống **E-Service Quản trị Tập trung** được thiết kế phục vụ riêng cho hai nhóm đối tượng quản trị nội bộ: **Cán bộ Bộ Giáo dục (`MOEHQ`)** và **Cán bộ / Ban Giám hiệu Nhà trường (`SCHOOL`)**.

Khác biệt với luồng đăng nhập công dân (SingPass) của phụ huynh, luồng xác thực này có các đặc thù:

- **Không qua bên thứ ba (No Third-Party IdP):** Người dùng nhập trực tiếp Username và Password trên giao diện E-Service, không chuyển hướng qua cổng định danh GovTech/MockPass.
- **Không tự đăng ký / Không JIT (No Self-Registration / No Just-In-Time Provisioning):** Tất cả tài khoản quản trị đều được khởi tạo thủ công từ trước trong cơ sở dữ liệu bởi Quản trị viên hệ thống. Người dùng không thể tự đăng ký.
- **Không có MFA:** Đăng nhập một bước sử dụng cặp thông tin định danh (Username/Password).
- **Tuân thủ chuẩn bảo mật Pure BFF (Pattern 2):** Trình duyệt **hoàn toàn không lưu trữ JWT Access Token hay Refresh Token** trong `LocalStorage`, `SessionStorage` hay JavaScript Memory Context. Thay vào đó, Trình duyệt chỉ lưu duy nhất một **Cookie bảo mật (`IAM_Session`)** chứa mã phiên ngẫu nhiên (`s:<guid>`).
- **Tra cứu và đóng dấu Header tại Gateway:** Toàn bộ dữ liệu JWT nhạy cảm được cất giữ an toàn tại **Redis Cache**. **API Gateway (:5273)** đóng vai trò cửa ngõ: đối chiếu Cookie với Redis, bóc tách JWT rồi "đóng dấu" (inject) thông tin định danh (`X-User-Id`, `X-User-Roles: MOEHQ` hoặc `X-User-Roles: SCHOOL`, `X-Session-Id`) vào HTTP Header trước khi chuyển tiếp yêu cầu đến các dịch vụ nghiệp vụ nội bộ.

1.2 Sơ đồ tuần tự nghiệp vụ (Mermaid Sequence Diagram)



---

2. BẢN ĐỒ TÁC NHÂN & MA TRẬN VAI TRÒ (SERVICE REGISTRY & ROLES MATRIX)

2.1 Bảng phân vai dịch vụ

Tên Dịch vụ	Địa chỉ (Port)	Vai trò trong Hệ thống E-Service	Điểm QA cần chú ý kiểm tra
Frontend Admin Web	`:3000` / Web	Cổng thông tin giao diện dành cho cán bộ quản trị.	Form login trực tiếp; kiểm tra không rò rỉ token vào Storage của trình duyệt.
API Gateway (YARP)	`:5273`	Cửa ngõ trung gian duy nhất; tiếp nhận request, kiểm tra In-Memory Cache (60s), inject Header `X-*`.	Trả mã `401 Unauthorized` nếu session sai/hết hạn; chặn truy cập trái phép.
IAM Service	`:5290`	Xử lý logic đăng nhập, xác thực mật khẩu băm, phát hành JWT mang role `MOEHQ`/`SCHOOL`, ghi/đọc Redis.	Tiếp nhận trực tiếp các request xác thực từ Gateway; quản lý bảng `Users` và `UserRoles`.
Redis Cache	`:6379`	Kho lưu trữ tập trung ánh xạ `Opaque SessionId -> JWT Token`.	Key có định dạng `s:<guid>`, thời hạn sống TTL là 30 ngày (Sliding Expiration).
Core Admin Services	Nội bộ	Các dịch vụ nghiệp vụ (Báo cáo tổng hợp, Quản lý trường học, Học bổng, Học phí...).	Đọc các Header `X-User-Id`, `X-User-Roles` để phân quyền dữ liệu.

2.2 Ma trận Thẩm quyền Vai trò (RBAC Matrix)

Cả hai nhóm người dùng đều dùng chung một đường dẫn đăng nhập duy nhất (`/api/iam/v1/auth/admin/login`), nhưng hệ thống phân tách quyền hạn dựa trên vai trò được cấu hình sẵn trong cơ sở dữ liệu:

Tiêu chí	Vai trò `MOEHQ` (Bộ Giáo dục)	Vai trò `SCHOOL` (Cán bộ Nhà trường)
Đối tượng sử dụng	Lãnh đạo Bộ, Chuyên viên phòng ban cấp Bộ.	Hiệu trưởng, Cán bộ hành chính, Giáo vụ trường học.

Tiêu chí	Vai trò `MOEHQ` (Bộ Giáo dục)	Vai trò `SCHOOL` (Cán bộ Nhà trường)
Phạm vi Dữ liệu (Scope)	**Toàn ngành (National/All):** Xem và quản lý dữ liệu trên phạm vi tất cả các trường trong hệ thống.	**Nội bộ Trường (Single-Tenant/School):** Chỉ được xem và xử lý dữ liệu của trường học mà tài khoản trực thuộc.
Quyền hạn Nghiệp vụ	Xem dashboard báo cáo tổng hợp toàn quốc, phê duyệt ngân sách/trợ cấp toàn ngành, cấu hình danh mục dùng chung.	Quản lý danh sách học sinh thuộc trường, duyệt đơn miễn giảm học phí của trường, theo dõi thu học phí của trường.
Header Gateway inject	`X-User-Roles: MOEHQ`	`X-User-Roles: SCHOOL`

3. ĐẶC TẢ CHI TIẾT 4 BƯỚC XÁC THỰC & DỮ LIỆU MẪU (STEP-BY-STEP PAYLOADS)

Bước 1: Tiếp nhận thông tin đăng nhập trực tiếp (Direct Credential Auth)

1. Cán bộ truy cập cổng E-Service và nhập Username cùng Password trên form đăng nhập.
2. Trình duyệt gửi request xác thực:
    - **Endpoint:** `POST https://gateway:5273/api/iam/v1/auth/admin/login`
    - **Header:** `Content-Type: application/json`

- **Request Body mẫu - Cán bộ Bộ Giáo dục (`MOEHQ`):**

```
{
  "username": "hq_director_tan",
  "password": "HQSecurePassword2025!@"
}
```

- **Request Body mẫu - Cán bộ Nhà trường (`SCHOOL`):**

```
{
  "username": "officer_raffles_sec",
  "password": "SchoolOfficerPass2025#$"
}
```

3. **Xử lý tại IAM Service (:5290):**
    - IAM truy vấn thông tin trong cơ sở dữ liệu nội bộ:

```
SELECT u.id, u.username, u.password_hash, u.status, r.name as role_name
FROM users u
JOIN user_roles ur ON u.id = ur.user_id
JOIN roles r ON ur.role_id = r.id
WHERE u.username = @username;
```

    - **Kiểm tra nghiệp vụ:**

- Nếu không tìm thấy Username: Trả về HTTP `401 Unauthorized` (Hệ thống **không tự động tạo user**, không có JIT).
- Nếu tài khoản có trạng thái `Inactive` hoặc `Locked`: Trả về HTTP `403 Forbidden` kèm thông báo tài khoản bị khóa.
- So sánh mật khẩu bằng thuật toán mã hóa (Argon2 / BCrypt). Nếu sai mật khẩu: Trả về HTTP `401 Unauthorized`.

Bước 2: Cấp phát phiên BFF & Cất Token vào Redis (Session Minting)

1. Sau khi xác thực mật khẩu thành công, IAM Service phát hành:
   - **Access Token (JWT nội bộ):** Chứa thông tin nhận diện người dùng và quyền hạn (`roles: ["MOEHQ"]` hoặc `roles: ["SCHOOL"]`).
   - **Refresh Token:** Mã ngẫu nhiên dài hạn phục vụ việc tự động gia hạn.
2. IAM sinh ra một `SessionId` ngẫu nhiên chuẩn GUID: `s:9c8b7a6d-5e4f-3a2b-1c0d-9e8f7a6b5c4d`.
3. IAM lưu toàn bộ dữ liệu phiên vào Redis Cache:
   - **Key:** `s:9c8b7a6d-5e4f-3a2b-1c0d-9e8f7a6b5c4d`
   - **TTL:** `2,592,000 giây` (30 ngày - Giữ cơ chế Sliding Expiration như flow SingPass).
   - **Value lưu trong Redis (JSON):**


```
{
  "sessionId": "s:9c8b7a6d-5e4f-3a2b-1c0d-9e8f7a6b5c4d",
  "userId": "usr_adm_hq_8899",
  "username": "hq_director_tan",
  "roles": ["MOEHQ"],
  "accessToken":
"eyJhbGciOiJSUzI1NiIsInR5cCI6IkpXVCJ9.eyJzdWIiOiJ1c3JfYWRtX2hxXzg4OTkiL
CJ1c2VybmFtZSI6ImhxX2RpcmVjdG9yX3RhbiIsInJvbGVzIjpbIk1PRUhRIl0sImV4cCI6
MTcxOTU2MDAwMH0.signature_hash_xyz",
  "refreshToken": "rf_admin_sec_8844aabbccdd",
  "createdAt": "2025-05-15T09:00:00Z"
}
```


4. **Response trả về cho Trình duyệt:**
   - **HTTP Status:** `200 OK`
   - **Header thiết lập Cookie an toàn:**

```
Set-Cookie: IAM_Session=s:9c8b7a6d-5e4f-3a2b-1c0d-9e8f7a6b5c4d; Path=/;
HttpOnly; Secure; SameSite=Lax
```

   - **Response Body mẫu:**

```
{
  "success": true,
  "user": {
    "id": "usr_adm_hq_8899",
    "username": "hq_director_tan",
    "role": "MOEHQ"
```

```
    }
  }
```

(Lưu ý bắt buộc cho QA: Body phản hồi tuyệt đối KHÔNG chứa accessToken hay refreshToken).

Bước 3: Thao tác Nghiệp vụ Quản trị & Gateway Header Injection

1. Cán bộ bấm vào màn hình quản trị, trình duyệt tự động đính kèm Cookie `IAM_Session`:

```
GET /api/v1/admin/national-summary HTTP/1.1 --fake-url
Host: gateway:5273
Cookie: IAM_Session=s:9c8b7a6d-5e4f-3a2b-1c0d-9e8f7a6b5c4d
Accept: application/json
```

2. **Xử lý tại API Gateway (:5273):**
   - Gateway trích xuất giá trị `s:9c8b7a6d...` từ Cookie `IAM_Session`.
   - Tra cứu In-Memory Cache (TTL 60 giây):
     - *Nếu Hit Cache:* Lấy trực tiếp thông tin JWT đã lưu sẵn trong RAM.
     - *Nếu Miss Cache:* Gọi nội bộ `GET /api/v1/auth/session/s:9c8b7a6d.../resolve` sang IAM Service để đọc từ Redis, sau đó ghi nhớ vào In-Memory Cache trong 60 giây.
   - Gateway xác thực chữ ký JWT, kiểm tra thời hạn và bóc tách các Claims.
   - Gateway **"đóng dấu" (inject)** các Header định danh rồi chuyển tiếp yêu cầu đến Microservice nội bộ:

```
GET /api/v1/admin/national-summary HTTP/1.1 --fake-url
Host: internal-adminservice:5005
Authorization: Bearer eyJhbGciOiJSUzI1NiIsInR5cCI6IkpXVCJ9...
X-User-Id: usr_adm_hq_8899
X-User-Roles: MOEHQ
X-Session-Id: s:9c8b7a6d-5e4f-3a2b-1c0d-9e8f7a6b5c4d
```

Bước 4: Đăng xuất Tức thì (Instant Revocation)

1. Cán bộ bấm nút **"Đăng xuất" (Logout)** trên thanh công cụ E-Service.
2. Trình duyệt gửi request:

```
POST /api/iam/v1/auth/logout HTTP/1.1
Host: gateway:5273
Cookie: IAM_Session=s:9c8b7a6d-5e4f-3a2b-1c0d-9e8f7a6b5c4d
```

3. **Xử lý tại IAM Service (:5290):**
   - IAM nhận lệnh và thực hiện lệnh `DEL s:9c8b7a6d-5e4f-3a2b-1c0d-9e8f7a6b5c4d` trên Redis.
   - Bản ghi phiên bị tiêu hủy hoàn toàn trong cơ sở dữ liệu bộ nhớ.
4. Response trả về trình duyệt kèm lệnh xóa sạch Cookie:

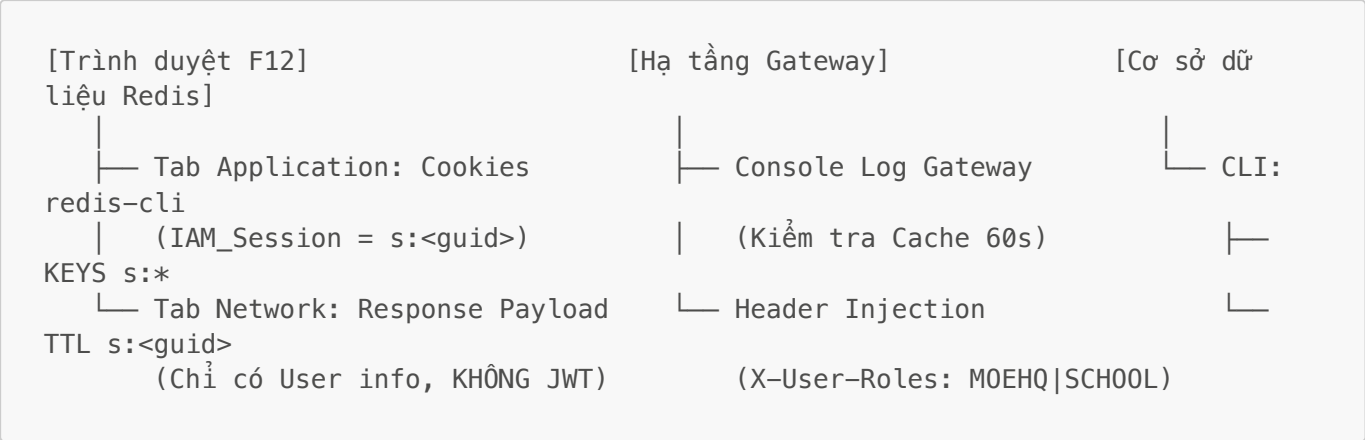
```
HTTP/1.1 200 OK
Set-Cookie: IAM_Session=; Path=/; Expires=Thu, 01 Jan 1970 00:00:00 GMT;
Max-Age=0
```

5. **Kiểm tra tính thu hồi quyền:** Bất kỳ thao tác nào sau đó sử dụng lại Cookie cũ sẽ lập tức bị Gateway chặn lại với mã `401 Unauthorized` (do Gateway gọi resolve sang IAM và nhận phản hồi `404 Session Not Found`).

---

4. SỔ TAY "SOI" DỮ LIỆU DÀNH CHO QA (QA DEVTOOLS & INSPECTION CHEATSHEET)

Khi kiểm thử các tính năng xác thực và phân quyền của E-Service, QA đối chiếu theo bảng chỉ dẫn kỹ thuật sau:



Bảng đối soát chi tiết:

Khu vực kiểm tra	Vị trí thao tác	Dấu hiệu nhận biết ĐẠT (Pass)	Dấu hiệu LỖI (Bug)
Cấu hình Cookie BFF	DevTools -> **Application** -> Storage -> Cookies	Tên cookie: `IAM_Session`. Giá trị bắt đầu bằng tiền tố: `s:`. Cột **HttpOnly** có dấu tích xanh. Cột **SameSite** có giá trị `Lax`.	Thiếu cờ `HttpOnly` hoặc `SameSite`; hoặc cookie bị rỗng sau khi đăng nhập thành công.
Bảo mật Body Response	DevTools -> **Network** -> request `admin/login`	Body JSON trả về chỉ chứa thông tin cơ bản: `id`, `username`, `role` (`MOEHQ` hoặc `SCHOOL`).	Body trả về có thuộc tính `accessToken: eyJ...` hoặc `refreshToken` (vi phạm mô hình BFF).
Kiểm tra Phiên trên Redis	Kết nối Redis CLI: `redis-cli`	Lệnh: `KEYS s:*` -> tìm thấy session tương ứng. Lệnh: `TTL s:<guid>` -> giá trị xấp xỉ `2592000` (giây).	Đăng nhập thành công nhưng không có key nào dạng `s:*` trên Redis.
Cơ chế Gateway Cache 60s	Console Log của API Gateway	Request 1: Có log `Resolving session from IAM`. Request 2-10 (trong vòng 60s): Không có log resolve sang IAM mà dùng cache RAM nội bộ.	Mỗi request gửi lên đều làm Gateway phải gọi ngược sang IAM Service để resolve (Cache không hoạt động).

Khu vực kiểm tra	Vị trí thao tác	Dấu hiệu nhận biết ĐẠT (Pass)	Dấu hiệu LỖI (Bug)
Đăng xuất tức thì	Redis CLI & Postman	Sau khi gọi `POST /api/iam/v1/auth/logout`: Lệnh `EXISTS s:<guid>` trên Redis trả về `0`. Dùng Postman gửi lại Cookie cũ -> Gateway trả về ngay `401 Unauthorized`.	Đã logout thành công nhưng key trên Redis vẫn còn; hoặc dùng lại Cookie cũ vẫn truy xuất được dữ liệu `200 OK`.

5. MA TRẬN KỊCH BẢN KIỂM THỬ NGHIỆP VỤ (QA TEST MATRIX)

5.1 Nhóm Kịch bản Luồng chuẩn (Happy Path Scenarios)

Mã Test Case	Tên Kịch bản	Dữ liệu đầu vào (Test Data)	Các bước thực hiện	Kết quả kỳ vọng (Expected Result)
TC-ESVC-01	Đăng nhập thành công với vai trò Cán bộ Bộ Giáo dục	Username: `hq_admin` Password: Đúng mật khẩu DB.	1. Truy cập trang E-Service Login. 2. Nhập thông tin tài khoản HQ. 3. Bấm Đăng nhập.	- API `POST /api/iam/v1/auth/admin/login` trả về `200 OK`. - Trình duyệt nhận Cookie `IAM_Session`. - Vào Dashboard cấp Bộ, hiển thị quyền `MOEHQ`. - Redis xuất hiện key `s:*` chứa role `MOEHQ`.
TC-ESVC-02	Đăng nhập thành công với vai trò Cán bộ Nhà trường	Username: `school_officer` Password: Đúng mật khẩu DB.	1. Truy cập trang E-Service Login. 2. Nhập thông tin tài khoản Trường. 3. Bấm Đăng nhập.	- API `POST /api/iam/v1/auth/admin/login` trả về `200 OK`. - Trình duyệt nhận Cookie `IAM_Session`. - Vào Dashboard cấp Trường, hiển thị quyền `SCHOOL`. - Redis xuất hiện key `s:*` chứa role `SCHOOL`.
TC-ESVC-03	Kiểm tra Gateway In-Memory Cache 60 giây	Cookie của phiên hợp lệ.	1. Gửi request `GET /api/v1/admin/profile` lần 1. 2. Gửi lại API này liên tục 5 lần trong vòng 30 giây.	- Cả 5 lần đều nhận HTTP `200 OK`. - Log Gateway xác nhận: Chỉ lần 1 gọi sang IAM Service, 4 lần sau lấy thông tin trực tiếp từ In-Memory Cache.

5.2 Nhóm Kịch bản Xác thực & Bảo mật (Authentication & Security Scenarios)

Mã Test Case	Tên Kịch bản	Dữ liệu đầu vào (Test Data)	Các bước thực hiện	Kết quả kỳ vọng (Expected Result)
TC-ESVC-04	Đăng nhập với Username không tồn tại (Không có JIT)	Username: `ghost_user_999` Password: `AnyPassword123!`	1. Nhập username chưa từng được tạo trong Database. 2. Bấm Đăng nhập.	- API trả về HTTP `401 Unauthorized`. - Database không tự tạo bản ghi mới (xác nhận không có JIT/Register). - Không có session nào được tạo trên Redis.
TC-ESVC-05	Đăng nhập đúng Username nhưng sai Mật khẩu	Username: `hq_admin` Password: `WrongPassword@123`	1. Nhập đúng tài khoản nhưng nhập sai mật khẩu. 2. Bấm Đăng nhập.	- API trả về HTTP `401 Unauthorized` kèm thông báo lỗi chung. - Không cấp phát Cookie `IAM_Session`.
TC-ESVC-06	Đăng nhập với tài khoản đang bị Khóa / Vô hiệu hóa	Tài khoản có cột `status = 'Disabled'` trong Database.	1. Nhập đúng username và password của tài khoản bị khóa. 2. Bấm Đăng nhập.	- API trả về HTTP `403 Forbidden` (Account is disabled/locked). - Không sinh session trong Redis.
TC-ESVC-07	Kiểm tra chống đánh cắp Cookie qua XSS Script	Script: `document.cookie`	1. Đăng nhập thành công vào E-Service. 2. Bật Console trình duyệt (F12), chạy: `console.log(document.cookie)`.	- Chuỗi in ra **hoàn toàn không chứa** Cookie `IAM_Session` (nhờ cờ `HttpOnly = true`).
TC-ESVC-08	Giả mạo Cookie Session ID	Cookie giả: `IAM_Session=s:00000000-fake-session-id`	1. Thay đổi giá trị Cookie `IAM_Session` trên trình duyệt thành chuỗi ngẫu nhiên. 2. Tải lại trang (F5).	- Gateway tra cứu Redis không thấy session. - Trả về HTTP `401 Unauthorized`. - Chuyển hướng người dùng về

Mã Test Case	Tên Kịch bản	Dữ liệu đầu vào (Test Data)	Các bước thực hiện	Kết quả kỳ vọng (Expected Result)
				màn hình Đăng nhập.

5.3 Nhóm Kịch bản Phân quyền Ranh giới & Thu hồi Phiên (RBAC & Revocation)

Mã Test Case	Tên Kịch bản	Dữ liệu đầu vào (Test Data)	Các bước thực hiện	Kết quả kỳ vọng (Expected Result)
TC-ESVC-09	Cán bộ Trường cố truy cập API đặc quyền của Bộ Giáo dục	Phiên đăng nhập có vai trò `SCHOOL`.		